

OWASP JUICE SHOP

Security Assessment Report

Prepared For: OWASP Juice Shop (TryHackMe Lab)

Report Issued: 2025

Confidentiality Notice: This report contains sensitive, privileged, and confidential information. Precautions should be taken to protect the confidentiality of the information in this document. Publication of this report may cause reputational damage or facilitate attacks against the assessed system.

Disclaimer: This assessment may not disclose all vulnerabilities present on the systems within scope. This is a point-in-time assessment. Any changes to the environment during testing may affect results.

TABLE OF CONTENTS

- 1. [Executive Summary](#)
- 2. [High Level Assessment Overview](#)
- 3. [Scope](#)
- 4. [Testing Methodology](#)
- 5. [Classification Definitions](#)
- 6. [Assessment Findings](#)
- 7. [Appendix A - Tools Used](#)
- 8. [Appendix B - Engagement Information](#)

EXECUTIVE SUMMARY

A penetration test was performed against the OWASP Juice Shop web application hosted at `10.114.140.87`. The assessment simulated a real-world attacker targeting the web application with the goal of identifying and exploiting vulnerabilities across multiple categories including injection, broken authentication, sensitive data exposure, broken access control, and cross-site scripting (XSS). A total of **15 vulnerabilities** and challenge flags were identified and exploited during the engagement.

CRITICAL	HIGH	MEDIUM	LOW	INFORMATIONAL
0	5	6	3	1

The most severe findings include SQL Injection enabling full administrative account takeover, stored/reflected/DOM-based XSS vulnerabilities, unauthenticated access to sensitive FTP files, and broken access control allowing horizontal privilege escalation into other users' shopping baskets. Immediate remediation of injection and authentication flaws is strongly recommended.

HIGH LEVEL ASSESSMENT OVERVIEW

Observed Security Strengths

No significant security controls were observed that effectively prevented the tested attacks. The application serves as an intentionally vulnerable training target.

Areas for Improvement

Short Term Recommendations

- Sanitize all user inputs server-side to prevent SQL Injection and XSS attacks.
- Implement strong password policies and enforce multi-factor authentication for admin accounts.
- Remove or restrict access to the publicly exposed `/ftp/` directory.
- Apply proper session management and authorization checks on all API endpoints.

Long Term Recommendations

- Integrate a Web Application Firewall (WAF) to detect and block common attack patterns.
 - Conduct regular security training for development teams on OWASP Top 10 vulnerabilities.
 - Adopt a DevSecOps approach integrating security testing into the CI/CD pipeline.
 - Implement Content Security Policy (CSP) headers to mitigate XSS impact.
-

SCOPE

All testing was performed on the OWASP Juice Shop application as defined in the engagement scope.

Target Application

Host	Application	Note
10.114.140.87	OWASP Juice Shop	Intentionally vulnerable Node.js web application

Provided Credentials / Discovered Accounts

Account	Email	Note
Admin	admin@juice-sh.op	Discovered via product page; exploited via SQL injection
Jim	jim@juice-sh.op	Discovered via Green Smoothie product review
Bender	bender@juice-sh.op	Discovered via Banana Juice product review
MC SafeSearch	mc.safesearch@juice-sh.op	Discovered via Juice Shop Permafrost 2020 Edition page

TESTING METHODOLOGY

The testing methodology was split into three phases: **Reconnaissance**, **Target Assessment**, and **Exploitation**.

Phase 1 - Reconnaissance

Burp Suite was configured as a proxy with Intercept set to off. The application was browsed manually (walking the application) to allow Burp to log all HTTP requests and responses. This revealed user emails, hidden endpoints, and application structure.

Phase 2 - Target Assessment

JavaScript source files (`main-es2015.js`) were analyzed to discover hidden routes such as `/#/administration`. Product reviews, error messages, and HTTP headers were analyzed for information disclosure. The `/ftp/` directory was enumerated directly.

Phase 3 - Exploitation

Identified vulnerabilities were exploited to demonstrate real-world impact, including SQL injection for account takeover, XSS payload injection across three vectors, directory traversal via Poison Null Byte bypass, and broken access control via manipulated API parameters.

CLASSIFICATION DEFINITIONS

Risk Classifications

Level	Score	Description
Critical	10	Immediate threat; successful exploitation may permanently affect the organization. Remediate immediately.
High	7-9	Urgent threat; remediation should be prioritized.
Medium	4-6	Exploitation possible and may result in notable disruption. Remediate when feasible.

Level	Score	Description
Low	1-3	Negligible/minimal threat. Note and remediate if possible.
Info	0	No clear threat but may reveal sensitive information or alter expected behavior.

Exploitation Likelihood Classifications

Likelihood	Description
Likely	Well-known methods, publicly available tools. Low-skilled attackers can exploit with minimal effort.
Possible	Well-known methods but may require configuration and understanding of the underlying system.
Unlikely	Requires deep technical skill or precise conditions for successful exploitation.

Business Impact Classifications

Impact	Description
Major	Large disruptions to critical business functions and significant financial damage.
Moderate	Significant disruptions to non-critical business functions.
Minor	Affects few users without major disruption to routine functions.

Remediation Difficulty Classifications

Difficulty	Description
Hard	Extensive reconfiguration required; may disrupt normal business operations.
Moderate	Minor reconfigurations needed; may be time-intensive or expensive.
Easy	Accomplished in a short time with little difficulty.

ASSESSMENT FINDINGS

#	Finding	Risk Score	Risk Level
1	SQL Injection - Admin Login Bypass	9	High
2	SQL Injection - Account Takeover (Bender)	8	High
3	Broken Authentication - Weak Admin Password	8	High
4	Persistent XSS via HTTP Header (True-Client-IP)	8	High
5	Broken Access Control - Admin Panel Exposed	7	High
6	Reflected XSS via Order Tracking ID	6	Medium
7	DOM XSS via Search Bar	6	Medium
8	IDOR - View Other Users' Baskets	6	Medium
9	Sensitive Data Exposure - Public /ftp/ Directory	6	Medium
10	Broken Authentication - Password Reset via Security Question	5	Medium
11	Broken Authentication - Credentials in Public Media	5	Medium
12	Poison Null Byte - File Extension Restriction Bypass	4	Medium
13	Information Disclosure - Admin Email via Product Page	3	Low
14	Information Disclosure - User Emails via Reviews	3	Low
15	Missing Access Control - Unauthorized Deletion of Reviews	2	Low

1 - SQL Injection - Admin Login Bypass

HIGH RISK (9/10)

Exploitation Likelihood	Likely
Business Impact	Major
Remediation Difficulty	Easy

Security Implications

An attacker can log into the administrator account without knowing the password by injecting a

SQL payload into the login form, granting full administrative access to the application.

Analysis

The login endpoint does not sanitize user input before including it in the SQL query. By entering `' or 1=1--` as the email and any value as the password, the backend SQL query always returns true and authenticates as the first user in the database (the admin). The admin email

`admin@juice-sh.op` was discovered via the Apple Juice product page.

Flag: `690fa3247a99d651e0b26f947baf0b79b4f404a9`

Recommendations

- Use parameterized queries / prepared statements for all database interactions.
- Implement input validation and server-side sanitization on all login fields.
- Deploy a Web Application Firewall to detect SQL injection patterns.

References

- https://owasp.org/www-community/attacks/SQL_Injection
-

2 - SQL Injection - Account Takeover (Bender)

HIGH RISK (8/10)

Exploitation Likelihood	Likely
Business Impact	Major
Remediation Difficulty	Easy

Security Implications

Any registered user account can be hijacked without a password using a SQL comment-based injection on the login page.

Analysis

By entering `bender@juice-sh.op'--` as the email, the SQL query ignores the password check entirely and authenticates as Bender. The account email was discovered via a Banana Juice product review.

Flag: `5ff5052e879e6fef64124e64c82c84ebc809c6c4`

Recommendations

- Use parameterized queries / prepared statements for all database interactions.
 - Enforce server-side input validation on all authentication endpoints.
-

3 - Broken Authentication - Weak Admin Password

HIGH RISK (8/10)

Exploitation Likelihood	Likely
Business Impact	Major
Remediation Difficulty	Easy

Security Implications

The administrator account uses a trivially guessable password (`admin123`), allowing unauthorized access via brute force or simple guessing without any bypass techniques.

Analysis

After discovering the admin email through the Apple Juice product page, the password `admin123` was guessed manually. The application does not enforce password complexity or account lockout policies.

Flag: `ff4aebffe31b0ffdea9bdd0207a16a3c01ac6c56`

Recommendations

- Enforce a strong password policy (minimum 12 characters, mixed case, numbers, symbols).
- Implement account lockout after repeated failed login attempts.
- Enable multi-factor authentication (MFA) for all privileged accounts.

4 - Persistent XSS via HTTP Header (True-Client-IP)

HIGH RISK (8/10)

Exploitation Likelihood	Likely
Business Impact	Major
Remediation Difficulty	Moderate

Security Implications

A stored XSS payload injected via the `True-Client-IP` HTTP header is rendered unsanitized on the Last Login IP page, executing malicious JavaScript for every admin viewing the page.

Analysis

By intercepting the logout request in Burp Suite and adding the header `True-Client-IP: <iframe src="javascript:alert('xss')">`, the payload is stored server-side. Upon next admin

login and navigation to the Last Login IP page, the XSS executes.

Flag: `c37da14686b69a220fd9febd09bb9593e7d0539f`

Recommendations

- Sanitize and validate all HTTP request headers before storing or rendering them.
- Implement a Content Security Policy (CSP) header to restrict script execution sources.
- Encode all output rendered from user-controlled or header-sourced data.

References

- <https://owasp.org/www-community/attacks/xss/>

5 - Broken Access Control - Admin Panel Exposed via JavaScript

HIGH RISK (7/10)

Exploitation Likelihood	Likely
Business Impact	Major
Remediation Difficulty	Easy

Security Implications

The administration panel route is embedded in client-side JavaScript, allowing any user who inspects the source to navigate to `/#/administration` and access admin functions.

Analysis

By opening Firefox DevTools > Debugger and loading `main-es2015.js`, the route `path: 'administration'` was found via text search for "admin". Navigating to `/#/administration` while authenticated as admin revealed full control over user reviews and feedback.

Flag: `71aeb3b0bf01cc6e488f0207bb62f79b41454a87`

Recommendations

- Enforce server-side authorization checks on all admin API endpoints; do not rely on client-side route hiding.
 - Restrict the administration panel to specific IP ranges or require additional authentication.
 - Remove or obfuscate sensitive route information from bundled JavaScript files.
-

6 - Reflected XSS via Order Tracking ID

MEDIUM RISK (6/10)

Exploitation Likelihood	Likely
Business Impact	Moderate
Remediation Difficulty	Easy

Security Implications

User-supplied input in the order tracking URL parameter is reflected in the page response without sanitization, enabling reflected XSS attacks against any user who clicks a crafted link.

Analysis

By navigating to Order History, clicking the truck (tracking) icon, and replacing the tracking ID in the URL with `<iframe src="javascript:alert('xss')">`, the XSS payload executes on page load.

Flag: `305021787d3e9cd9cebc057a021c2504550bb3b6`

Recommendations

- Sanitize and encode all URL parameters before including them in server responses or rendering them in the DOM.
- Implement Content Security Policy (CSP) headers.

7 - DOM XSS via Search Bar

MEDIUM RISK (6/10)

Exploitation Likelihood	Likely
Business Impact	Moderate
Remediation Difficulty	Easy

Security Implications

The application search bar passes user input directly into the DOM without sanitization, allowing DOM-based XSS payloads to execute in the browser.

Analysis

Entering `<iframe src="javascript:alert('xss')">` into the search bar triggered a JavaScript alert dialog. The search parameter is processed client-side and written into the DOM unsafely.

Flag: `4a31a4fe0954199566e360a873802bf64d0d0a84`

Recommendations

- Avoid using `innerHTML` or other unsafe DOM manipulation methods with user-supplied data.
- Use safe DOM APIs such as `textContent` or `createTextNode`.
- Implement a strict Content Security Policy (CSP) to prevent inline script execution.

References

- https://owasp.org/www-community/attacks/DOM_Based_XSS
-

8 - Insecure Direct Object Reference - View Other Users' Baskets

MEDIUM RISK (6/10)

Exploitation Likelihood	Likely
Business Impact	Moderate
Remediation Difficulty	Easy

Security Implications

The `/api/basket/{id}` endpoint does not validate that the requesting user owns the basket, allowing any authenticated user to view another user's shopping basket by manipulating the ID.

Analysis

While logged in as admin, intercepting the `GET /rest/basket/1` request in Burp Suite and changing the basket ID from `1` to `2` returned another user's basket contents without any authorization error.

Flag: `e6982b34b6734ceadd28e5019b251f929a80b815`

Recommendations

- Implement server-side ownership checks on all object references.
 - Use indirect references (e.g., session-tied tokens) rather than predictable sequential IDs.
-

9 - Sensitive Data Exposure - Public /ftp/ Directory

MEDIUM RISK (6/10)

Exploitation Likelihood	Likely
-------------------------	--------

MEDIUM RISK (6/10)

Business Impact	Major
Remediation Difficulty	Easy

Security Implications

The `/ftp/` directory is publicly accessible without authentication, exposing confidential business documents including an acquisitions file and developer backup files.

Analysis

Navigating to `http://10.114.140.87/ftp/` revealed a directory listing containing `legal.md`, `acquisitions.md`, and `package.json.bak` among others. Discovered via the "Check out our terms of use" link on the About Us page.

Flag: `8d2072c6b0a455608ca1a293dc0c9579883fc6a5`

Recommendations

- Remove the `/ftp/` directory from public web server access immediately.
- Implement access controls and authentication for any file-serving directories.
- Audit all web-accessible directories for unintended file exposure.

10 - Broken Authentication - Password Reset via Weak Security Question (Jim)

MEDIUM RISK (5/10)

Exploitation Likelihood	Likely
Business Impact	Moderate
Remediation Difficulty	Easy

Security Implications

Jim's account password can be reset by anyone who can research the answer to his security question, which references a publicly known pop culture fact.

Analysis

Jim's email (`jim@juice-sh.op`) was found in a Green Smoothie product review mentioning a "replicator" (a Star Trek reference). His security question answer (`Samuel`, his brother's middle name) was researchable via OSINT, enabling a full password reset via the Forgot Password page.

Flag: `3c3e2d6ef99b733b947e92f8e2a9ed08bf57ea63`

Recommendations

- Replace knowledge-based security questions with multi-factor authentication.

- Implement rate limiting and CAPTCHA on the password reset endpoint.

11 – Broken Authentication – Credentials Embedded in Public Media

MEDIUM RISK (5/10)

Exploitation Likelihood	Likely
Business Impact	Moderate
Remediation Difficulty	Easy

Security Implications

MC SafeSearch's account password is disclosed in a publicly available promotional video, allowing anyone who watches it to log into the account.

Analysis

The promotional video (Juice Shop Permafrost 2020 Edition) includes a segment where the character states his password is "Mr. Noodles" with vowels replaced by zeros, yielding `Mr . N00dl3s` for account `mc.safeSearch@juice-sh.op`.

Flag: `bb105418e73708ceccf1a7b2491f434b8f5230e4`

Recommendations

- Never embed credentials or password hints in marketing or public-facing media.
- Enforce periodic password changes and ensure credentials are not shared externally.

12 – Poison Null Byte – File Extension Restriction Bypass

MEDIUM RISK (4/10)

Exploitation Likelihood	Possible
Business Impact	Moderate
Remediation Difficulty	Moderate

Security Implications

The `/ftp/` directory restricts file downloads to `.md` and `.pdf` extensions, but this control can be bypassed using a URL-encoded Poison Null Byte, allowing download of arbitrary files.

Analysis

Attempting to download `package.json.bak` returned a `403` error. By appending `%2500.md` to the filename in the URL (URL-encoded null byte `%00`), the server was tricked into allowing the download of the restricted backup file.

Flags: `dad737329153068527159005db4eb139e86e76ba` | `cfdeea14e8f01b4952722fd0e4a77f1928593c9a`

Recommendations

- Implement server-side file type validation using MIME type detection, not filename strings.
- Sanitize and reject URLs containing null bytes or other special characters before processing.
- Remove the `/ftp/` directory from public access entirely.

References

- https://owasp.org/www-community/attacks/Null_Byte_Injection

13 - Information Disclosure - Admin Email via Product Page

LOW RISK (3/10)

Exploitation Likelihood	Likely
Business Impact	Minor
Remediation Difficulty	Easy

Security Implications

The administrator's email address is displayed publicly on a product detail page, providing attackers with a valid username for brute force or social engineering attacks.

Analysis

Clicking on the Apple Juice product page revealed the email `admin@juice-sh.op` in the review section without requiring authentication.

Recommendations

- Avoid displaying internal or administrative email addresses on public-facing pages.
- Use display names or obfuscated identifiers for admin accounts.

14 - Information Disclosure - User Emails via Product Reviews

LOW RISK (3/10)

Exploitation Likelihood	Likely
Business Impact	Minor
Remediation Difficulty	Easy

Security Implications

Multiple user email addresses are exposed publicly in product reviews, enabling targeted phishing, account enumeration, and credential stuffing attacks.

Analysis

Product reviews on Green Smoothie (`jim@juice-sh.op`), Banana Juice (`bender@juice-sh.op`), and the Permafrost 2020 Edition page (`mc.safesearch@juice-sh.op`) displayed full email addresses without authentication.

Recommendations

- Replace email addresses with display names or usernames in publicly visible reviews.
- Audit all public-facing pages for unintended user data exposure.

15 - Missing Access Control - Unauthorized Deletion of Customer Reviews

LOW RISK (2/10)

Exploitation Likelihood	Possible
Business Impact	Minor
Remediation Difficulty	Easy

Security Implications

The admin panel allows deletion of all customer reviews including 5-star feedback without any audit trail, which could be abused to manipulate reputation or suppress legitimate user feedback.

Analysis

While authenticated as admin, navigating to `/#/administration` displayed all customer reviews with a delete (bin) icon. Clicking the icon next to any 5-star review permanently deleted it with no confirmation or logging.

Flag: `78231b75c0b2180b7e964dcbb1ab3c3f58639f2e`

Recommendations

- Implement an audit log for all administrative actions including content deletion.
- Add a confirmation step and require a reason before deleting user-generated content.

APPENDIX A - TOOLS USED

Tool	Description
Burp Suite Community Edition	HTTP proxy used for intercepting, modifying, and replaying web requests. Used for all injection and XSS testing.
Firefox DevTools (Debugger)	Used to inspect bundled JavaScript files and discover hidden application routes.
Web Browser	Used for manual application walking, reconnaissance, and confirming exploits.
Google / OSINT	Used to research security question answers (Star Trek replicator reference for Jim's account).

APPENDIX B - ENGAGEMENT INFORMATION

Client Information

Field	Detail
Client	OWASP Juice Shop (TryHackMe Lab Environment)
Application URL	http://10.114.140.87
Assessment Type	Web Application Penetration Test
Testing Approach	Grey Box (application browsed with Burp proxy; no source code provided)

Version Information

Version	Date	Description
1.0	2025	Initial report - all findings from Juice Shop TryHackMe assessment

Flags Summary

Challenge	Flag
Login Admin (SQL Injection)	690fa3247a99d651e0b26f947baf0b79b4f404a9
Login Bender (SQL Injection)	5ff5052e879e6fef64124e64c82c84ebc809c6c4
Password Strength (admin123)	ff4aebffe31b0ffdea9bdd0207a16a3c01ac6c56
Reset Jim's Password	3c3e2d6ef99b733b947e92f8e2a9ed08bf57ea63
Confidential Document (/ftp/)	8d2072c6b0a455608ca1a293dc0c9579883fc6a5
Login MC SafeSearch	bb105418e73708ceccf1a7b2491f434b8f5230e4
Error Handling	9c297196ecf8890bc1e900fcf3aebae8c9f9880a
Forgotten Developer Backup	dad737329153068527159005db4eb139e86e76ba
Poison Null Byte	cfdeea14e8f01b4952722fd0e4a77f1928593c9a
Admin Section	71aeb3b0bf01cc6e488f0207bb62f79b41454a87
View Basket (IDOR)	e6982b34b6734ceadd28e5019b251f929a80b815
Five-Star Feedback Deletion	78231b75c0b2180b7e964dcbb1ab3c3f58639f2e
DOM XSS	4a31a4fe0954199566e360a873802bf64d0d0a84
HTTP-Header XSS (Persistent)	c37da14686b69a220fd9febd09bb9593e7d0539f
Reflected XSS	305021787d3e9cd9cebc057a021c2504550bb3b6
Score Board	2614339936e8282e2f820f023d4d998a1f95e02a